Informe: seguridad de expedientes académicos

Laboratorio local de pruebas de seguridad · 30 de octubre de 2026

Estudiante: _____ Curso: _____ Docente: _____

Material didáctico. Datos y tokens ficticios, solo en 127.0.0.1. Este informe describe lo verificado en el laboratorio; no afirma seguridad absoluta.

1. Actores y alcance

Estudiantes (Ana/Central, Luis/Pacífico), docentes (María/Central, Pedro/Pacífico), Admin (global) y una sesión expirada. Operaciones evaluadas: leer expediente, actualizar nota y revocar sesión.

2. Requisitos de seguridad

ID	Requisito
R1	Un estudiante solo puede leer su propio expediente.
R2	Un docente solo puede leer y modificar notas de expedientes de su sede.
R3	El administrador puede leer todos los expedientes pero no modificar notas.
R4	Sesiones ausentes, desconocidas, revocadas o expiradas reciben 401 y no acceden a nada.
R5	La nota debe ser un número real en [0,100]; cualquier otro valor da 400.
R6	Las respuestas de error (401/403/400) no incluyen notas ni datos confidenciales.
R7	Un cambio rechazado deja intacta la nota original.
R8	La auditoría registra usuario, acción y resultado, nunca el token.

3. Amenazas

ID	Amenaza	Categoría
A1	Acceso horizontal: Ana lee el expediente de Luis (IDOR).	Divulgación de información
A2	Acceso vertical: estudiante o admin modifican notas.	Elevación de privilegios
A3	Docente de una sede modifica o lee notas de otra sede.	Elevación / divulgación
A4	Reutilización de sesión revocada o expirada.	Suplantación
A5	Notas manipuladas con valores fuera de rango o de tipo inesperado (-1, 1000, true, NaN).	Manipulación de datos
A6	Fuga de tokens por la bitácora de auditoría.	Divulgación de información
A7	Mensajes de error que revelan datos o reglas internas.	Divulgación de información

4. Matriz requisito - riesgo - prueba

Requisito	Amenaza	Defecto	Pruebas
R1	A1	SEC-01	N01, P01
R2	A3	SEC-01 / SEC-02	N04, N06, P02
R3	A2	SEC-02	N05, P03
R4	A4	SEC-03	N02, N03, N07
R5	A5	SEC-04	N08, F01, F02
R6	A7	SEC-01	N01, N04, F03
R7	A5	SEC-02 / SEC-04	N03, N04, N08, F02
R8	A6	Auditoría	X01

5. Casos de prueba (12 de diseño, todos automatizados)

ID	Tipo	Descripción	Resultado esperado
P01	Positivo	Estudiante lee su propio expediente	200
P02	Positivo	Docente cambia nota en su sede	200, nota actualizada
P03	Positivo	Admin lee expedientes de ambas sedes	200
N01	Negativo	Estudiante lee expediente ajeno	403, sin datos
N02	Negativo	Lectura con sesión revocada	401, sin datos
N03	Negativo	Sesión expirada lee y modifica	401, nota intacta
N04	Negativo	Docente cambia nota de otra sede	403, nota intacta
N05	Negativo	Estudiante y admin cambian notas	403, nota intacta
N06	Negativo	Docente lee expediente de otra sede	403, sin datos
F01	Frontera	Notas 0 y 100	200
F02	Frontera	Notas -1, -0.01, 100.01, 101, 1000	400, nota intacta
F03	Frontera	Expediente inexistente	404, sin datos
N07*	Extra	Token vacío o desconocido	401
N08*	Extra	Texto, null, true, NaN, inf, lista como nota	400
X01*	Extra	Auditoría sin tokens	Sin campo ni valor de token
X02*	Extra	Permisos se evalúan antes que el dato	403 (no 400)

* Pruebas adicionales a los 12 casos pedidos. Total: 16 pruebas unitarias y 20 pruebas de API.

6. Desarrollo guiado por pruebas (TDD)

Ciclo 1: SEC-01 y SEC-03

- **Rojo:** N01 y N06 (la lectura entre estudiantes y entre sedes devolvía 200 con la nota); N02 y N03 (sesión revocada y expirada devolvía 200).
- **Verde:** función `_puede_leer()` por rol, sede y propiedad; `autenticar()` rechaza sesiones revocadas o expiradas.
- **Refactor:** la política de lectura quedó en una sola función y la auditoría en `_auditar()`.

Ciclo 2: SEC-02 y SEC-04

- **Rojo:** N04 (María cambiaba notas de Pacífico), N08 (`true` se aceptaba como nota) y F02 (rangos).
- **Verde:** verificación de sede en `actualizar_nota()` y `_nota_valida()` (rechaza bool, NaN, infinito y fuera de [0,100]).
- **Refactor:** los permisos se evalúan antes que la validación del dato (X02), para no revelar reglas a quien no tiene permiso.

Evidencia: antes de corregir, la suite nueva dio **8 fallos de 16**; después de corregir, **16 de 16 en verde**. Las 20 pruebas de API (script `ejecutar_todo.ps1`) también resultaron correctas (20 de 20).

7. Hallazgos

ID	Severidad	Hallazgo	Corrección
SEC-01	Alta	Cualquier sesión válida leía cualquier expediente (horizontal y entre sedes).	Autorización por rol, sede y propiedad; 403 sin datos.
SEC-02	Alta	Cualquier docente modificaba notas de otra sede.	Verificación de sede; 403 y nota intacta.
SEC-03	Alta	Sesiones revocadas y expiradas seguían autenticando; revocar no tenía efecto real.	autenticar() las rechaza con 401.
SEC-04	Media	Se aceptaban notas fuera de [0,100] y booleanos (True cuenta como número en Python).	_nota_valida().
SEC-05	Media	La auditoría guardaba el token completo.	Se registra usuario, acción, id y resultado; los denegados también se auditan.
SEC-06	Baja	Content-Length negativo en el servidor podía dejar la petición esperando datos.	Se responde 400.

8. Dictamen de liberación

Para el alcance del laboratorio (uso didáctico local): LIBERABLE. Los defectos SEC-01 a SEC-06 están corregidos y verificados con pruebas unitarias y de API.

Para cualquier uso real: BLOQUEADO. Riesgo residual:

- La autenticación es sintética: los tokens son texto fijo (lab-ana), sin firma, contraseñas ni caducidad real.
- Las sesiones "expiradas" son una bandera; no hay reloj ni expiración automática.
- No hay HTTPS, límite de intentos, protección contra fuerza bruta ni aislamiento por tenant en el almacenamiento.
- Un 404 frente a un 403 permite confirmar si un ID de expediente existe (enumeración).
- La auditoría vive en memoria y no es inmutable.
- La cobertura se limita a los casos diseñados; no sustituye una revisión de seguridad completa.